Segurança nas Pipelines — SAST, DAST, SCA, Secrets

Bernoulli · repositório `pipeline-templates` (Azure DevOps, org bernoullidevops / Produtos Digitais, branch `devops`) · 22/09/2026

Categoria	Estado atual	Lacuna	Proposta	Prioridade
SAST (SonarQube)	Pausa intencional Segue desligado de propósito (decisão da equipe, não bug). Continua chamado em todas as famílias, atrás do parâmetro `enabled` (default `false`).	Nenhuma análise estática roda hoje — mas por decisão consciente, não por lacuna.	Sem ação necessária agora. Infra pronta (SonarQube self-hosted) pra quando a pausa for revista.	Baixa
SCA (OWASP Dependency-Check)	Ativo e funcionando Roda como Job próprio (`SCA_DependencyCheck`), com agente e checkout próprios, em paralelo ao Build — chama diretamente o template de steps `setup/dependency-check.yml`, sem depender do SonarQube nem de nenhum outro Job. Presente nas 6 famílias de orquestrador (webapp, function, function-container, static-web, SWA, container apps).	Cobertura total — nenhuma lacuna nos orquestradores.	Sem ação necessária.	Baixa
Secrets (Gitleaks)	Ativo e funcionando Toggle `enableGitleaks` por repositório (modo `warn`, telemetria própria no App Insights interno). Presente nas 6 famílias de orquestrador (webapp, function, function-container, static-web, SWA, container apps).	Cobertura total nos orquestradores; roda em modo `warn`, não bloqueia merge hoje.	Avaliar promover de `warn` para bloqueante em produção.	Média
Imagens de contêiner	Nunca existiu Nenhuma menção a scanner de imagem nos templates, apesar de Container Apps / Function / WebApp em contêiner publicarem no ACR.	Cobertura total ausente.	Trivy como step no build (grátis, esforço baixo) ou Microsoft Defender for Containers (nativo — confirmar se Defender for Cloud já está habilitado antes de assumir custo novo).	Média
DAST	Nunca existiu Nenhuma menção em nenhum template.	Nenhuma aplicação é testada em runtime.	OWASP ZAP baseline scan (grátis) contra o ambiente alpha pós-deploy, começando informativo. Esforço médio-alto (alvo, autenticação, falso positivo).	Baixa/Média